

Information Security Due Diligence Procedure

**Standard Operating Procedure: Information Security Due Diligences****Standard Operating Procedure for Information Security Due Diligence**

Version	3.0
Effective Date	12/03/2025
Compiled by	Hiten Kumar
Reviewed by	Ratnesh Singh
Approved by	Chief Information Security Officer (CISO)

Revision and Version Control:

Version	Date	Reason for Revision/Update	Created/Updated By	Reviewed By	Approved By
1.0	28-02-2023	First Copy	Hiten Kumar	Nikhil Bhujade	CISO
2.0	09-10-2024	RACI matrix added	Hiten Kumar	Ratnesh Singh	CISO
3.0	12-03-2025	Updated Reporting & TAT defined	Hiten Kumar	Ratnesh Singh	CISO

Standard Operating Procedure: Information Security Due Diligences

Contents

1. Introduction.....	4
2. Objective	4
3. Scope	4
4. Definition	4
5. Information Security Due Diligence Methodology	4
6. Frequency of Information Security Due Diligence	5
7. Reporting and TAT.....	5
8. Roles and Responsibilities	5
9. RACI Matrix	6
10. REVIEW:.....	6

Classification | INTERNAL

Standard Operating Procedure: Information Security Due Diligences

1. Introduction

This document outlines information security due diligence methodology and provides guidance on Infosec due diligence requirement. Further, it also outlines the frequency of performing Infosec Due diligence. It also provides clarity on responsibilities and accountabilities for the various participants in the overall management of Infosec due diligence in the organization. It encompasses the following areas:

- Identifying the data flow and their related risks, applicable threats, vulnerabilities, and existing controls.
- Self-validation or declaration from vendor on information security compliance.
- Evaluating the security risks from information security due diligence perspective.
- Determining security risks associated with new projects or product enhancement.
- Obtain risk owner's approval or acceptance of the residual risk.

2. Objective

The objectives of performing information security due diligence are to protect the organization and its ability to perform its daily operations which shall be accomplished by:

- Getting Information security assurance on the information systems that store, process, or transmit organizational information.
- Self-Validation or self-declaration from vendor end on security parameters compliance.
- Safeguards organization interest and ensures risks are identified prior to vendor onboarding.
- Provides continuous assurance of information security controls for onboarded vendors.
- Assessment of potential compliance or regulatory risks related to information security and data security controls within the vendor environment.
- Identification of high-risk vendors holding sensitive or personally identifiable information of PFL customers.

3. Scope

With reference to Standard Operating Procedure 'Vendor Onboarding & Monitoring & IT Outsourcing' - Risk Management Framework Ver 2.0, Every new vendor onboarding requires the concerned onboarding unit to conduct Materiality assessment and follow the needful requirement basis the Materiality assessment outcome e.g., information security assessment if vendor qualifies for it.

Indicative checklist wherein Infosec Assessment is must.

- Third party Integration with PFL system.
- Application Host customer PII data.
- Vendor requires dedicated access to PFL infrastructure for application support.

4. Definition

PFL	Poonawalla Fincorp Limited
PII	Personal Identifiable Information
SOP	Standard Operating Procedure
IT Team	Information Technology Team
Infosec	Information Security
TAT	Turn Around Time

5. Information Security Due Diligence Methodology

Information security due diligence is an integral element of the overall Information Security framework at Poonawalla Fincorp. Poonawalla Fincorp is committed to safeguarding its business by implementing processes & controls, documented in information security policies and procedures. This ensures security of the organization's business processes and operations while minimizing the risks. This is accomplished by:

- Promoting information security assessments during vendor onboarding.

Standard Operating Procedure: Information Security Due Diligences

- Conducting timely Infosec due diligence to gauge risks accurately and holistically.
- Focusing on the continuous improvement of security operations.
- Complying with regulations and industry standards.
- Preventing and investigating the occurrence of security breaches.
- A risk-based approach is adopted in conducting such due diligence activities.
- Infosec due diligence ensures BCP and DR capabilities in vendors and partners critical interconnected systems.
- For vendor evaluation- vendor risk assessment sheet is required to be filled out by vendors.

6. Frequency of Information Security Due Diligence

Information Security due diligence performing shall be performed during the following stages:

A. During vendor onboarding - On Ad hoc Basis

Any new vendor which is being on-board by the organization shall be assessed by information security team if the vendor or service provided by the vendor qualifies for Infosec assessment as per the defined criteria.

B. Periodic vendor due diligence – Annually

For all existing and new vendors qualifying for information security due diligence, periodic assessment shall be conducted on yearly basis or including vendors which handle customer PII data or any of the following events (may not be exhaustive):

- If major changes are contemplated to existing systems/assets or business processes.
- Significant changes to existing processes where customer data is exchanged.
- Any new or existing vendor, if it qualifies for Infosec assessment during materiality assessment conducted by risk team.

7. Reporting and TAT

The Information Security team shall compile the periodic vendor due diligence report, including observation risk ratings.

The Information Security team will periodically follow up with stakeholders to ensure timely closure of identified issues.

Turnaround Time (TAT) for Observation Closure

- High – 30 Days
- Medium – 90 Days
- Low – 180 Days

Note: Observation tracking shall be done based on the date of publishing the respective report.

8. Roles and Responsibilities

A. Risk Team

As per “Standard Operating Procedure Vendor Onboarding & Monitoring & IT Outsourcing - Risk Management Framework Ver 2.0 “. Operation Risk Team is doing materiality assessment of new IT vendors and If vendor qualifies for level2 infosec assessment it will be forwarded to infosec team for their review. Information security due diligence will be applicable to new vendors based on some criteria. Vendors will consider for Information security due diligence if 3 out of 5 questions are marked as “Yes”.

- Does the vendor Application/vendor, host OR have access to PFL employee OR customer PI data/information.
- Is vendor managing Infra where PFL employee OR customer PI data/information are stored.

Standard Operating Procedure: Information Security Due Diligences

- Any Third-party tools integrated with PFL Application
- Is BCP of application managed by vendor.
- Does the vendor require dedicated access to PFL server and/or system.

B. Information Security Team

- The information security team is responsible for ensuring Information security due diligence for qualified vendors during vendor onboarding and continuous assurance post vendor onboarding.
- The information security team shall also perform security assessments for new IT projects and Information system Integration.
- Vetting vendor agreement for defining Information security requirements.
- During Infosec due diligence below reports of vendor also need to be reviewed.
 - a. Vulnerability assessment- API /Systems
 - b. SOC2 report (wherever applicable)
 - c. BCP-DR test reports
 - d. External audit reports like ISO 27001/Information system audit.
 - e. Vendor risk assessment sheet.

C. IT application Team/ Business Team

- IT applications are responsible for getting clearance for the information IT projects, existing IT system if any changes occur like change in data flow, system integration etc. IT Approach document to be prepared (wherever required) and shared with information security team for review for any system integration.

9. RACI Matrix

Action Item(s)	Responsible	Accountable	Consulted	Informed
Information security due diligence for selected vendors.	Information security team	Business Team/IT application	CISO	ORM, CRO
Security assessment for new IT projects and Information system Integration.	Information security team	IT Application	Business Team	CISO
Review of vendor due diligence of existing vendor	Information security team	Business Team/IT application	CISO	ORM
Getting clearance from Infosec on new IT projects	Business Team	IT Application	Information security team	CISO, CRO
Preparing IT Approach document	IT Application	Business Team	Information security team	CISO

10. REVIEW:

Information security due diligence SOP shall be reviewed annually or whenever any changes happen.